

Cerebro Field Notes

How Security Operations Really Runs It

Security Operations Engineering

Internal Brownbag

Why Cerebro Matters to SecOps

- ▶ Single security system of record: agents, API, CLI share one audited brain.
- ▶ Append-only telemetry with graph + SQL means instant forensic replay.
- ▶ Pluggable agents on Claude/OpenAI give analysts real-time automation without breaking trust.

Morning Intake Ritual

- ▶ 08:30 UTC: make dev spins up review UI + API locally for triage.
- ▶ Analysts create agent session via CLI or UI targeting orgs-on-call.
- ▶ `findings_list` tool runs with scoped CEL policies; results logged in audit trail.

Key Insight

Agents pull from the same Postgres tables as our dashboards.
No swivel chair.

Triage Playbook in Practice

```
session = runtime.create_session(  
    org_id=org_on_call,  
    agent_type="SECURITY_ANALYST",  
    context={"provider_scope": ["aws", "github"]},  
    title="Daily Findings Sweep"  
)
```

```
for finding in high_severity:  
    runtime.send_message(session,  
        f"Summarize {finding.id} and map controls")
```

- ▶ Session context locks provider scope; CEL policies enforce least privilege.
- ▶ Results land in `agent_messages` + `agent_audit_events` for full traceability.

Collection Service Workflow

- ▶ Collection orchestrator coordinates provider ports, identity stitching, notifications.
- ▶ Config collector bulk-upserts resources/principals, hashes configs, logs metrics.
- ▶ Identity stitcher clusters principals across SaaS; ties into IAM investigations.

SOC Use

Analysts trigger background jobs for new accounts; monitor via `'/collectors/tasks/id'`.

Query Engine as SecOps Workbench

- ▶ Zero-ETL SQL engine registers provider tables; run ad-hoc hunts with 'cerebro query'.
- ▶ SOC dashboards call '/api/v1/query/execute' for real-time posture slices.
- ▶ Evidence bundles pull SQL outputs into WORM storage for incident packages.

Agent-Assisted IR Loop

- ▶ Incident responder agent seeds session with incident ID + finding IDs.
- ▶ Tools used: `timeline`, `forensic_replay`, `attack_path_simulator`.
- ▶ Audit logs show tool invocations, approvals, and Celery job IDs.

Operational Benefit

Reconstruct timeline with consistent data model shared by CLI/API/agents.

Evidence Capture Pipeline

```
bundle = WORMEvidenceBundle(  
    bundle_id=incident_id ,  
    created_by=oncall_engineer ,  
    organization_id=org_id ,  
)  
  
bundle.add_sql_query_evidence(  
    query="SELECT * FROM aws_iam_user WHERE mfa_enabled=false" ,  
    results=query_rows ,  
    collector="agent:timeline")  
bundle.seal(private_kms_key)
```

- ▶ Evidence bundles signed + timestamped; entries logged to transparency ledger.
- ▶ SOC stores bundle IDs in incident tickets for auditor-ready packages.

Control Testing Cadence

- ▶ Control tests run via CEL, SQL, manual evidence; results feed compliance dashboards.
- ▶ SOC reviews failed controls weekly; integrates with remediation queue.
- ▶ Policy attestations tracked alongside technical findings for unified reporting.

SOC Automation Priorities

- ▶ Auto-context loading for agents (org/system context) to reduce analyst prompting.
- ▶ Session memory persistence to carry findings between daily sweeps.
- ▶ Proactive agents watching for new critical findings and kicking off review tasks.

Runbooks + Guardrails

- ▶ ToolExecutor enforces dry-run by default; destructive actions route to review queue.
- ▶ CEL policies encode provider scopes, approval requirements, incident states.
- ▶ Limiter (SlowAPI) caps API abuse; Prometheus metrics exported via `'/metrics'`.

Deployment Footprint

- ▶ API + agents share ECS services; agent metrics optional via feature flag.
- ▶ Celery worker health exposed at `'/health/celery'`; used by on-call dashboards.
- ▶ Tectonic-built decks archived in `'docs/talks'` for knowledge sharing.

What SecOps Needs Next

- ▶ Prioritize knowledge base system to avoid repetitive context loads.
- ▶ Productize proactive monitoring agent to catch misconfigs before humans do.
- ▶ Tighten feedback loop: capture analyst corrections, feed back into tools + policies.

Contact: soc-engineering@writer.com